

Secure deployment environment

Filesystem

--- FILESYS-01 | /etc/fstab opcije montiranja ---

Bezbednosni cilj: Proverava kritične opcije za /tmp i /home:

- noexec: sprečava izvršavanje binarnih fajlova
- nosuid: sprečava setuid interpretaciju
- noatime: NE treba koristiti jer briše informacije o pristupu fajlovima

[INFO] Sadržaj /etc/fstab:

```
UUID=0bebc506-9d4c-4c46-8d2f-0b1c57877c2c /          ext4  errors=remount-ro 0    1
UUID=3082-9EC7 /boot/efi      vfat  umask=0077    0    1
/swapfile                                none  swap  sw           0    0
```

[WARN] /tmp nije posebno montiran u /etc/fstab - preporučuje se odvojena particija sa noexec,nosuid

[INFO] /home nije posebno montiran u /etc/fstab

--- FILESYS-02 | Dozvole na osetljivim fajlovima ---

Bezbednosni cilj: Fajlovi sa lozinkama i privatnim ključevima ne smeju biti čitljivi svim korisnicima. Proveravaju se /etc/shadow, MySQL config, SSH ključevi, i eventualni backup-ovi shadow fajla.

[OK] Shadow fajl (hešovi lozinki) (/etc/shadow) - Dozvole: 640, Vlasnik: root:shadow

[INFO] /etc/mysql/my.cnf nije pronađen (servis možda nije instaliran)

[INFO] /etc/mysql/debian.cnf nije pronađen (servis možda nije instaliran)

[WARN] Pronađen backup shadow fajla: /etc/shadow.org (dozvole: 640) - proveriti da li je neophodan

[WARN] Pronađen backup shadow fajla: /etc/shadow- (dozvole: 640) - proveriti da li je neophodan

--- FILESYS-03 | SUID/SGID binarni fajlovi ---

Bezbednosni cilj: SUID fajlovi se izvršavaju sa privilegijama vlasnika.

Svaki SUID root fajl je potencijalni vektor eskalacije privilegija.

Lista se mora ručno proveriti - traže se nestandardni ili neočekivani fajlovi.

--- FILESYS-04 | Fajlovi zapisivi svim korisnicima (world-writable) ---

Bezbednosni cilj: Fajlovi koje može menjati bilo koji korisnik su rizik.

Napadač koji dobije pristup može modifikovati konfiguracijske fajlove, skripte ili web sadržaj da bi proširio pristup.

[INFO] Fajlovi zapisivi svim korisnicima (isključen /proc):

[FAIL] Pronađeno 50 world-writable fajlova:

--- FILESYS-05 | Dozvole na backup direktorijumima i fajlovima ---

Bezbednosni cilj: Backup fajlovi često sadrže osetljive podatke (shadow, konfiguracije, baze). Ako su čitljivi svim, napadač može doći do lozinki.

[FAIL] Backup direktorijum /var/backups je čitljiv/pristupačan svim korisnicima (dozvole: 755)

[FAIL] Arhive čitljive svim korisnicima:

/home/minja/eclipse-jdk11/plugins/org.eclipse.wildwebdeveloper_0.5.13.202012011111/
node_modules/eslint-server/node_modules/vscode-jsonrpc/vscode-jsonrpc-6.0.0-next.2.tgz
(dozvole: 664)

/home/minja/apache-tomcat-9.0.41/bin/tomcat-native.tar.gz (dozvole: 777)

/home/minja/apache-tomcat-9.0.41/bin/commons-daemon-native.tar.gz (dozvole: 777)

/home/minja/Downloads/eclipse-jee-2020-12-R-linux-gtk-x86_64.tar.gz (dozvole: 664)

/home/minja/Downloads/OpenJDK11U-jdk_x64_linux_hotspot_11.0.10_9.tar.gz (dozvole: 664)

Services

--- SERVICE-01 | Pokrenuti servisi ---

Bezbednosni cilj: Identifikuje sve pokrenute servise. Svaki nepotreban servis povećava površinu napada i treba ga onemogućiti.

Izlistani svi servisi.

[WARN] NTP servis nije pronađen - vreme možda nije sinhronizovano (rizik za logove i SSL sertifikate)

[OK] Syslog servis je pokrenut

[WARN] rsyslog NIJE konfigurisan za slanje logova na udaljeni server - logovi se čuvaju samo lokalno

--- SERVICE-02 | SSH konfiguracija ---

Bezbednosni cilj: SSH je najčešći vektor napada na servere.

Proverava se: zabrana direktnog root logina, isključenost SSHv1,

zabrana TCP forwardinga, i korišćenje nestandardnog porta.

[WARN] SSH konfiguracioni fajl nije pronađen - SSH možda nije instaliran

--- SERVICE-03 | MySQL konfiguracija ---

Bezbednosni cilj: MySQL ne sme da bude dostupan sa spoljnih interfejsa.

Proverava se bind-address i prisustvo korisnika bez lozinke.

[INFO] MySQL konfiguracioni fajl nije pronađen (MySQL možda nije instaliran)

--- SERVICE-04 | Dozvole na skriptama pozvanim iz crontab-a ---

Bezbednosni cilj: Skripte koje izvršava root cron moraju biti zapisive samo od strane root-a. Inače, bilo koji korisnik može ubaciti maliciozan kod koji će biti izvršen sa root privilegijama.

[INFO] Pregled cron fajlova u /var/spool/cron/crontabs:

[INFO] Pregled cron fajlova u /var/spool/cron:

[INFO] Pregled cron fajlova u /etc/cron.d:

[INFO] Pregled cron fajlova u /etc/cron.daily:

[INFO] Pregled cron fajlova u /etc/cron.weekly:

[INFO] Pregled cron fajlova u /etc/cron.monthly:

[INFO] Sadržaj /etc/crontab:

SHELL=/bin/sh

17 * * * * root cd / && run-parts --report /etc/cron.hourly

25 6 * * * root test -x /usr/sbin/anacron || (cd / && run-parts --report /etc/cron.daily)

47 6 * * 7 root test -x /usr/sbin/anacron || (cd / && run-parts --report /etc/cron.weekly)

52 6 1 * * root test -x /usr/sbin/anacron || (cd / && run-parts --report /etc/cron.monthly)

[WARN] Check zahteva root pristup - preskočeno: root crontab

